

【中间件安全】IIS7.0 安全加固规范 - 微信公众号Bypass

版权声明：本文由Bypass原创发布，转载请保留出处。欢迎关注我的个人微信公众号：Bypass--，浏览更多精彩文章。 https://blog.csdn.net/qq_23936389/article/details/85013920

1. 适用情况

适用于使用IIS7进行部署的Web网站。

2. 技能要求

熟悉IIS配置操作，能够利用IIS进行建站，并能针对站点使用IIS进行安全加固。

3. 前置条件

- 1、根据站点开放端口、进程ID、确认站点采用IIS进行部署；
- 2、启用IIS

方法一：按Win键+R打开Windows运行，输入inetmgr,回车即可打开；

方法二：开始->管理工具->Internet 信息服务(IIS)管理器。

4. 详细操作

4.1 限制目录执行权限

- 1、在IIS中设置需要上传文件的目录，双击处理程序映射



- 2、在处理程序映射中，把编辑功能权限中的脚本去掉，这样即使上传了木马文件在此目录，也是无法执行的。



4.2 开启日志审计

1、打开IIS管理工具，选择需要设置日志的站点，切换到功能视图，双击日志，进入日志配置界面。



2、默认情况下Web日志存放于系统目录" %SystemDrive%\inetpub\logs\LogFiles"，将Wb日志文件放在非网站目录和非操作系统分区，并定期对Web日志进行异地备份。

双击日志，可进行日志属性的设置如下图：

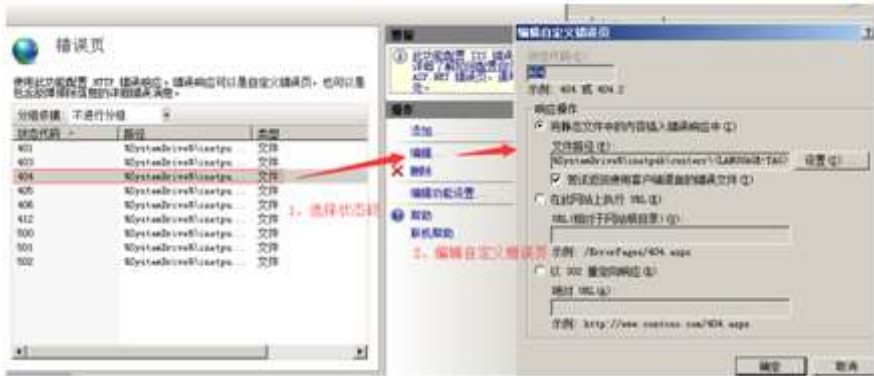


4.3 自定义404错误页面

1、选择站点，在功能视图页面，双击错误页，进入错误页配置页面：



2、选择404状态代码，进入自定义错误页编辑状态：



4.4 最佳经验实践

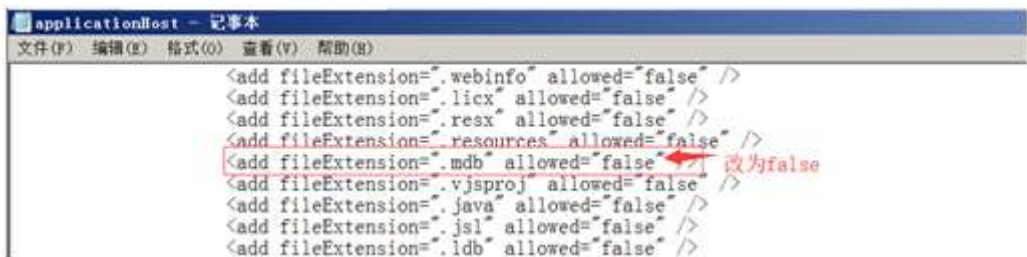
4.4.1 防止.mdb数据库文件被下载

很多网站都是使用的是asp+access数据库，mdb路径可能被猜解，数据库很容易就被别人下载了，利用IIS设置可有效防止mdb数据库被下载。

步骤一：在 C:\Windows\System32\inet_srv\config目录下找到applicationHost文件；



步骤二：打开applicationHost文件，选择requestFiltering 下的节点：<add fileExtension=".mdb" allowed="false" />，修改allowed的值为 "false" ，mdb文件不能被下载。

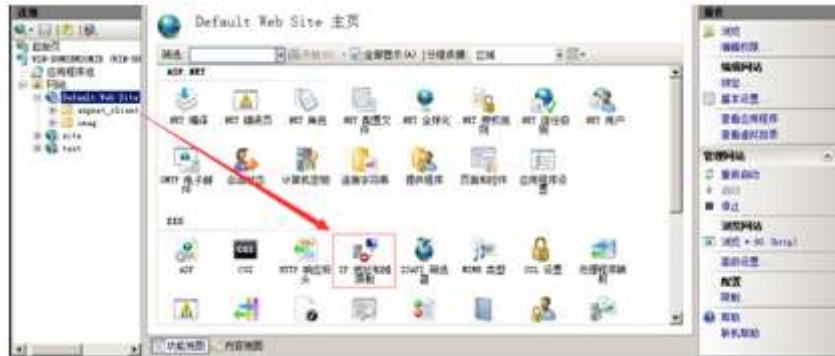


步骤三：保存后，即无法下载.mdb数据库文件。

4.4.2 访问源IP限制

在条件允许的条件下，对IIS访问源进行IP范围限制。只有在允许的IP范围内的主机才可以访问WWW服务。常用于限制网站管理后台对外开放。

1、开始->管理工具->Internet 信息服务(IIS)管理器 选择相应的站点目录，然后在功能视图中找到IP地址和域名限制，双击IP地址和域名限制进入设置。



2、在IP地址和域限制中，添加允许条目



4.4.3 关闭WebDAV

开始->管理工具->Internet 信息服务(IIS)管理器， 选择一个站点，在功能视图中找到WebDAV创作规则，双击WebDAV创作规则，进入设置：



2、在WebDAV创作规则中，选择禁用WebDAV



4.4.4 关闭目录浏览

开始->管理工具->Internet 信息服务(IIS)管理器 选择相应的站点目录，然后在功能视图页面找到“目录浏览”，双击进入目录浏览设置页面：



2、在最右边，操作栏进行“禁用”，即可禁用目录浏览



4.4.5 关闭FTP匿名访问

开始->管理工具->Internet 信息服务(IIS)管理器 点击WIN-主机名后在中间位置FTP栏找到FTP身份验证，双击进入；



右键匿名身份验证->禁用，即可关闭FTP匿名访问



4.4.6 解决IIS短文件名漏洞

1、打开Internet 信息服务(IIS)管理器，选择站点，在功能视图界面，双击请求筛选



2、在URLà添加拒绝序列àURL序列设置为【~】



4.5 风险操作项

4.5.1 停用或删除默认站点

IIS安装后的默认主目录是“C:\inetpub\wwwroot”，为更好地抵抗踩点、刺探等攻击行为，应该更改主目录位置，禁用默认站点，新建立站点并进行安全配置。

开始->管理工具->Internet 信息服务(IIS)管理器 选择相应的站点，然后右键站点，选择停止或者删除。



4.5.2 删除不必要的脚本映射

打开IIS服务管理器，选择需要设置的站点，找到“处理程序映射”双击，从列表中删除以下不必要的脚本。

包括 .asa .cer .cdx .idq .htw .ida .shtml .stm .idc .htr .printer等。

删除的原则：只保留需要的脚本映射。



根据需要可以在已经存在的脚本上点击右键进行编辑和删除，也可以自定义添加映射。



4.5.3 设置最大并发连接数

打开IIS服务管理器，选择需要设置的站点，点击浏览网站下的“高级设置”，打开高级设置对话框，切换到“连接限制”选项卡，设置连接限制，包括最大并发连接数等的设置。



4.5.4 独立站点帐户

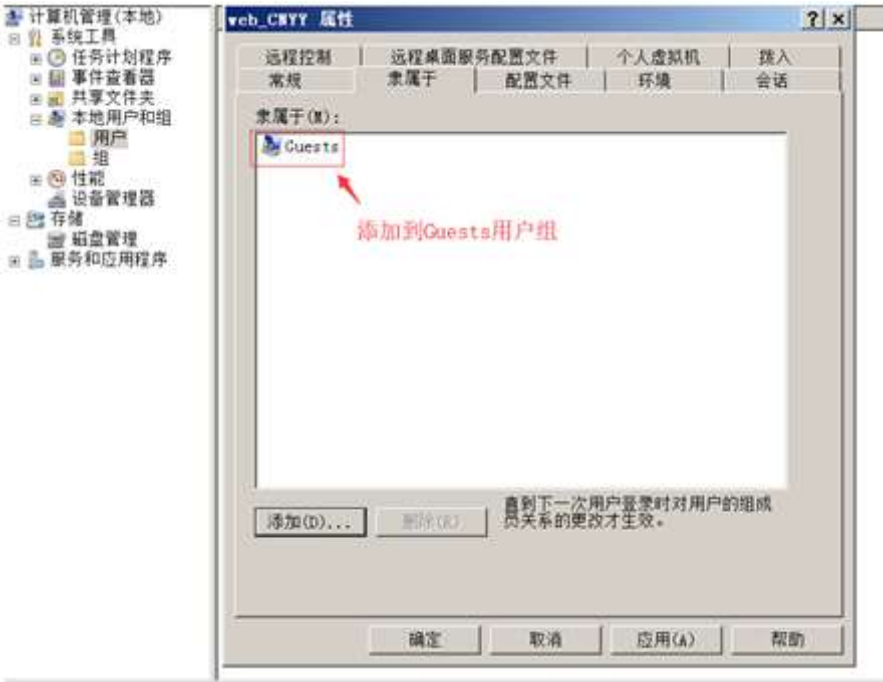
在Windows server 2008R2系统下，用IIS架设Web服务器，合理的为每个站点配置独立的Internet来宾账号，这样可以限制Internet 来宾账号的访问权限，只允许其可以读取和执行运行网站所需要的程序。

1. 选中“我的电脑”右键，选择“管理”，打开“计算机管理”，选择“本地用户和组”，然后点击“用户”，接着“右键”，新建一个用户，如下图：



最后点击“创建”，完成用户创建。

2. 删除新建的用户属的用户组“USERS”，然后点击“添加”，让用户属于Guests组，如下图：



3、网站设置独立运行用户，加强网站安全



4.5.5 独立应用程序池

给网站设置独立运行的程序池，这样每个网站与错误就不会互相影响：





4.5.6 卸载不需要的IIS角色服务

开始 -> 管理工具 -> 服务器管理器 双击 “角色” , 在右边最下方可以看见角色服务, 点击 “删除角色服务” , 可对不需要的IIS角色服务进行删除。



最后

欢迎关注个人[微信公众号](#)：Bypass--，每周原创一篇技术干货。



- 1、打开Internet 信息服务(IIS)管理器，选择站点，在功能视图界面，双击请求筛选
- 2、在URLà添加拒绝序列àURL序列设置为【~】